

Public Comment to NIST Center for AI Standards and Innovation (CAISI)

Re: NCCoE Concept Paper — "Accelerating the Adoption of Software and AI Agent Identity and Authorization"

Submitted by: Agent Identity Registry (AIR) Foundation **Organization Type:** 501(c)(3) Nonprofit Corporation **Date:** April 3, 2026 **Contact:** foundation@agentidentityregistry.org **Web:** <https://agentidentityregistry.org> **Specification:** <https://github.com/ahnkwangwook-oss/agent-identity-registry>

1. Introduction to the Agent Identity Registry Foundation

The Agent Identity Registry (AIR) Foundation appreciates the opportunity to submit this public comment in response to the National Cybersecurity Center of Excellence (NCCoE) concept paper on accelerating the adoption of software and AI agent identity and authorization. We commend NIST and CAISI for their leadership in recognizing that AI agent identity is a critical infrastructure challenge requiring coordinated standards development and cross-sector collaboration.

Who We Are

The AIR Foundation is a 501(c)(3) nonprofit organization dedicated to building neutral, transparent infrastructure for AI agent identity and trust. Founded in 2025 and headquartered in San Francisco, AIR operates as an independent registry providing identity verification, trust scoring, and verifiable credentials for AI agents. Our work is built entirely on open standards — specifically the W3C Decentralized Identifiers (DIDs) and Verifiable Credentials (VCs) specifications — and is released under the Apache License 2.0.

Our Mission

AIR's mission is to serve as a neutral trust layer for the agentic era — analogous to what ICANN provides for the domain name system or what Let's Encrypt provides for TLS certificate infrastructure. We believe that as AI agents become principal actors in digital commerce, infrastructure management, and interpersonal communication, the trust infrastructure governing their identity must be operated in the public interest, free from undue commercial influence.

Our Governance

AIR is governed by a 7-member Board of Directors composed entirely of independent experts in AI ethics, standards architecture, decentralized identity, nonprofit finance, global AI policy, blockchain infrastructure, and AI security. No corporate representative holds a board seat. Our governance charter includes:

- **Staggered 3-year board terms** to ensure continuity and prevent capture
- **Three standing committees:** Technical Steering Committee (TSC), Trust & Verification Committee (TVC), and Community & Ethics Committee (CEC) — each elected by or drawn from the community
- **Conflict-of-interest policies** requiring annual disclosures and recusal from interested votes
- **Whistleblower protections** with anonymous reporting channels
- **Public decision-making** with mandatory comment periods for policy and technical changes
- **Financial controls** including annual independent audits, published IRS Form 990 filings, and an explicit prohibition on pay-to-play influence

This governance structure is modeled on established internet governance organizations, including ICANN and the Internet Society, and is documented in full at our public repository.

Why We Are Commenting

We submit this comment not as a competing standards effort but as a complementary implementation voice. AIR seeks to bring NIST's standards frameworks to life as a neutral, operational registry. We believe our experience developing a comprehensive agent identity specification, trust scoring methodology, and governance charter positions us to offer substantive observations on the concept paper's proposals and to identify gaps where additional work may strengthen the overall framework.

2. Response to Concept Paper Sections: Gaps AIR Addresses

We recognize the concept paper as a substantial and well-structured contribution to the agent identity landscape. Its treatment of the agent identity lifecycle, its grounding in established protocols (OAuth 2.0, OpenID Connect, SPIFFE), and its attention to risk management and continuous monitoring reflect the rigor that the community expects from NIST. We offer the following observations on areas where the framework could be strengthened.

2.1 Consumer-Facing Trust Visibility

Observation: The concept paper's discussion of agent identity and authorization focuses primarily on machine-to-machine interactions, enterprise identity management, and developer-facing infrastructure. This is appropriate and necessary. However, the framework does not address how agent identity and trust information will be made visible and comprehensible to end users — the individuals who will increasingly interact with AI agents in consumer, civic, and personal contexts.

The gap: As AI agents move beyond enterprise back-office functions into consumer-facing roles — customer service, financial advising, healthcare triage, legal guidance, educational tutoring — individuals will need accessible mechanisms to evaluate agent trustworthiness before delegating sensitive tasks. The existing identity and authorization standards referenced in the concept paper (OAuth 2.0, OIDC, SPIFFE) were designed for system-to-system trust establishment, not for human-readable trust communication.

AIR's approach: AIR has developed a consumer-facing trust communication framework built around a Trust Score (0-1000) mapped to letter grades (AAA through C) with clear interpretive guidance for different use cases. This is analogous to the credit scoring system's consumer-facing grades or the ENERGY STAR labeling system's consumer-facing efficiency ratings. The intent is not to replace the technical identity and authorization protocols addressed in the concept paper, but to provide a legible trust signal layer that sits atop those protocols.

Recommendation: We encourage NIST to consider incorporating guidance on consumer-facing trust visibility into the framework. As agent interactions extend beyond enterprise boundaries, standardized approaches to communicating agent trustworthiness to non-technical users will become a critical adoption factor. The concept paper's discussion of monitoring and risk management could be extended to include human-interpretable trust indicators as an output of the agent identity lifecycle.

2.2 Neutral Governance of Agent Identity Infrastructure

Observation: The concept paper appropriately references multiple industry standards and protocols as building blocks for agent identity infrastructure. However, its discussion of governance and operational responsibility for agent identity systems does not explicitly address the question of institutional neutrality — that is, who should operate the registries, directories, and trust verification services that implement these standards.

The gap: The current agent identity landscape includes several well-resourced efforts, but most are governed by commercial entities or industry consortia with inherent conflicts of interest. Enterprise solutions such as Microsoft Entra Agent ID and Okta's Auth0 for AI Agents serve their customers well but operate within vendor ecosystems. Open-source initiatives such as AGNTCY (under the Linux Foundation, with a governing board including Cisco, Dell, Google, Oracle, and Red Hat) offer broader access but remain subject to corporate board governance. Protocol-level efforts such as Google's Agent2Agent (A2A) are led by individual corporations.

None of these approaches is inherently problematic, and each serves legitimate needs. But the concept paper's vision of broad adoption and interoperability across the agent identity ecosystem would benefit from

explicit consideration of the role that independent, nonprofit governance can play in preventing fragmentation and ensuring that trust infrastructure serves all stakeholders — not only those represented on corporate governing boards.

Historical precedent: The internet's foundational infrastructure provides instructive examples. The Domain Name System is governed by ICANN, a nonprofit corporation operating under a multi-stakeholder model. TLS certificate infrastructure was democratized by Let's Encrypt (operated by the Internet Security Research Group, a 501(c)(3) nonprofit), which now secures over 300 million websites. The W3C, IETF, and IEEE operate as independent standards bodies precisely because the infrastructure they govern must serve the entire ecosystem.

Recommendation: We encourage NIST to include explicit guidance on governance models for agent identity infrastructure, with particular attention to the role of independent nonprofits. The concept paper could reference established governance models (ICANN, ISRG/Let's Encrypt, the OpenID Foundation) as templates and recommend that operational agent identity registries adopt governance structures that include conflict-of-interest protections, public decision-making processes, and accountability mechanisms independent of commercial interests.

2.3 Comprehensive Trust Scoring Beyond Identity Verification

Observation: The concept paper's treatment of agent identity focuses appropriately on authentication and authorization — establishing that an agent is who it claims to be and that it is authorized to perform specific actions. These are necessary conditions for trust, but they are not sufficient.

The gap: Identity verification answers the question "Who is this agent?" Authorization answers "What is this agent allowed to do?" But the questions that users, platforms, and other agents increasingly need answered are broader: "How has this agent actually behaved?" "How transparent is its creator about its limitations?" "What do independent third parties attest about its capabilities?" "How secure is its underlying infrastructure?"

Current standards efforts address pieces of this puzzle in isolation. The IETF AIMS draft (draft-klrc-aiagent-auth-00) composes WIMSE, SPIFFE, and OAuth 2.0 for authentication. The OWASP Agent Name Service provides naming and discovery. ERC-8004 provides on-chain reputation. But no single framework provides a comprehensive, multi-dimensional trust assessment that integrates identity, behavior, transparency, security, and peer attestation into a unified score.

AIR's approach: AIR's Trust Score methodology addresses this gap through a five-component model:

Component	Weight	What It Measures
Provenance	25%	Creator identity, development practices, source transparency, training data documentation
Behavioral	25%	Production performance metrics, error rates, consistency, incident history
Transparency	20%	Documentation quality, limitation disclosures, community engagement, openness to scrutiny
Security	15%	Certifications (SOC 2, ISO 27001), infrastructure security, incident response capabilities
Peer Attestations	15%	Independent third-party verifications from diverse organizations

Each component is scored on a 0-1000 scale with detailed rubrics, evidence requirements, and minimum thresholds for each grade level. The composite score maps to letter grades (AAA through C) with clear interpretive guidance. The full methodology is published openly, subject to annual independent audit, and governed by AIR's Trust & Verification Committee with community input.

This approach is designed to complement, not replace, the authentication and authorization mechanisms discussed in the concept paper. Identity verification (via OAuth 2.0, OIDC, or SPIFFE) would inform the Provenance component. Continuous monitoring (as discussed in the concept paper's risk management sections) would inform the Behavioral component. The Trust Score aggregates these signals into a comprehensive assessment that is useful across different contexts — from automated agent-to-agent trust decisions to human-facing trust communication.

Recommendation: We encourage NIST to consider the role of multi-dimensional trust assessment in the agent identity framework. The concept paper's discussion of risk management and monitoring could be extended to include standardized approaches to trust scoring that go beyond binary authentication (verified/not verified) to provide graduated, evidence-based trust assessments. This would align with NIST's

own Risk Management Framework approach, which emphasizes continuous assessment across multiple dimensions.

2.4 Interoperability Across a Fragmented Standards Landscape

Observation: The concept paper references several established standards (OAuth 2.0, OpenID Connect, SPIFFE) as foundational protocols for agent identity and authorization. This is sound. However, the agent identity landscape as of early 2026 extends well beyond these protocols and includes at least 17 distinct initiatives across government standards bodies (NIST, IETF WIMSE, IETF AIMS), open standards consortia (W3C AI Agent Protocol CG, DIF Trusted AI Agents WG, OpenID Foundation AI Identity CG, OWASP ANS), industry-led open projects (Google A2A, AGNTCY), enterprise solutions (Microsoft Entra Agent ID, Okta Auth0, Aembit, CyberArk), blockchain registries (ERC-8004, SingularityNET/Privado ID), and academic research projects (MIT NANDA, Stanford Loyal Agents).

The gap: This fragmentation is both a strength (many approaches are being explored) and a risk (interoperability may suffer). The concept paper's focus on a specific set of protocols (OAuth 2.0, OIDC, SPIFFE) is pragmatic, but the framework would benefit from addressing how these protocols will interoperate with the broader ecosystem — particularly with W3C Decentralized Identifiers and Verifiable Credentials, which are increasingly adopted in decentralized identity contexts and are the foundation of several other agent identity initiatives (DIF Trusted AI Agents WG, SingularityNET/Privado ID, and AIR itself).

AIR's approach: AIR is designed as an interoperability layer. Our specification uses W3C DIDs as the foundational identifier format and W3C Verifiable Credentials as the attestation format, while remaining compatible with the OAuth 2.0 and OIDC protocols referenced in the concept paper. Agent Identity Documents use JSON-LD for semantic interoperability. The AIR ID format (AIR-XXXX-XXXX-XXXX, using base32 encoding with CRC32 checksums) is linked to underlying DIDs but provides a human-readable identifier suitable for cross-platform reference.

Our approach to interoperability is explicitly complementary:

- **NIST/NCCoE** sets the policy frameworks and security controls — AIR implements them through an independent, auditable registry
- **IETF WIMSE and AIMS** define authentication protocols — AIR uses them as infrastructure for the Provenance and Security components of trust assessment
- **W3C DID and VC standards** provide the foundational data models — AIR builds natively on them
- **OWASP ANS** provides naming and discovery — AIR provides the trust verification and scoring that makes discovered agents evaluable
- **AGNTCY** operates agent directories — AIR provides the trust verification layer that makes those directories trustworthy

Recommendation: We encourage NIST to address the interoperability challenge directly in the framework, with particular attention to how the OAuth 2.0/OIDC/SPIFFE stack will interface with the W3C DID/VC stack. Both represent significant standards investments by the community. A framework that bridges these two ecosystems — rather than selecting one over the other — would maximize adoption and minimize fragmentation. AIR's experience building on W3C standards while maintaining compatibility with OAuth/OIDC flows may offer a useful reference point.

3. AIR's Technical Approach

We provide the following technical summary to illustrate how an operational agent identity registry can implement the principles discussed in the concept paper. The full specification (v0.1 Draft) is available at our public repository.

3.1 AIR ID Format

Each registered agent receives a unique AIR ID in the format: `AIR-XXXX-XXXX-XXXX`

Where each segment is a 4-character base32-encoded string (using the character set A-H, J-N, P-Z, 2-7, excluding I, L, O, U to avoid visual ambiguity). The ID is generated as follows:

1. The Agent Identity Document (JSON) is serialized using canonical JSON encoding (RFC 8785)
2. A SHA-256 hash is computed over the serialized document
3. The first 8 bytes of the hash are base32-encoded to produce the first two segments (HEAD-TAIL)
4. A CRC32 checksum is computed over the full hash and base32-encoded to produce the third segment (CHECKSUM)
5. The final identifier is formatted as `AIR-HEAD-TAIL-CHECKSUM`

This format is cryptographically verifiable (recipients can recompute the hash from the identity document and confirm the ID), human-readable (suitable for display in user interfaces), and compact (19 characters total). Each AIR ID is linked to a W3C Decentralized Identifier (DID), enabling interoperability with the broader DID ecosystem.

3.2 Agent Identity Document

Agent Identity Documents use JSON-LD with the AIR context (`https://agentidentityregistry.org/v1`) and include:

- **Required fields:** `@context`, `type` ("AgentIdentity"), `air_id`, `name`, `creator` (including a W3C DID), and `created` (ISO 8601 timestamp)
- **Recommended fields:** `capabilities` (verified capability declarations), `security` (certifications, frameworks, audit dates, vulnerability disclosure program), `transparency` (open-source status, documentation URLs, stated limitations), `deployment` (platforms, API endpoints, SLA information), and `attestations` (W3C Verifiable Credentials from third parties)

This structure aligns with the concept paper's emphasis on comprehensive identity documentation while extending it to include transparency and behavioral metadata that support multi-dimensional trust assessment.

3.3 Trust Score Methodology

AIR's Trust Score is a composite assessment on a 0-1000 scale, computed as:

Trust Score = (0.25 × Provenance) + (0.25 × Behavioral) + (0.20 × Transparency) + (0.15 × Security) + (0.15 × Peer Attestations)

Each component is independently scored on a 0-1000 scale with published rubrics and evidence requirements. The composite score maps to letter grades:

Score Range	Grade	Interpretation
950-1000	AAA	Exceptional trust; suitable for critical infrastructure

900-949	AA	High trust; suitable for production in regulated industries
850-899	A	Good trust; suitable for general production use
800-849	BBB	Moderate trust; production use with monitoring
700-799	BB	Lower trust; controlled environments
600-699	B	Low trust; limited production, primarily testing
Below 600	C	Minimal trust; research and sandboxed use only

Key methodology features include:

- **Quarterly recalculation** incorporating the latest behavioral data, with accelerated recalculation if any component drops more than 50 points
- **New agent provisions:** Agents with fewer than 30 days of operational data have their Behavioral score capped at 500, with a maximum achievable composite score of approximately 750
- **Dispute resolution:** Agent creators may dispute scores within 30 days, with a structured review process
- **Annual independent audit** of the methodology itself, with audit reports published publicly

3.4 Verification Protocols

AIR defines four verification levels:

- **Level 1 — Self-Attested:** The agent creator declares capabilities and properties without independent verification
- **Level 2 — Organization Verified:** The creator's own organization conducts and attests to verification
- **Level 3 — Third-Party Verified:** An independent, certified auditor examines the agent and issues attestations
- **Level 4 — Foundation Verified:** The AIR Foundation itself conducts a formal audit under its published audit methodology

Verification results are issued as W3C Verifiable Credentials using the Ed25519Signature2020 proof type, enabling cryptographic verification by any party without dependence on a centralized authority.

3.5 API and Integration

The AIR registry exposes a REST API with the following core endpoints:

Method	Endpoint	Function
GET	/v1/agents/:air_id	Retrieve agent identity and trust score
POST	/v1/agents/register	Register a new agent
PUT	/v1/agents/:air_id	Update an agent identity document
GET	/v1/agents/:air_id/credentials	Retrieve all Verifiable Credentials
GET	/v1/agents/:air_id/trust-score	Retrieve detailed trust score breakdown
POST	/v1/credentials/verify	Verify a specific credential

GET	/v1/verifiers	List certified verifiers
-----	---------------	--------------------------

This API design is intentionally compatible with the RESTful patterns used in OAuth 2.0 token introspection and OIDC discovery.

3.6 Security Architecture

AIR's specification mandates:

- **EdDSA (Ed25519)** for all digital signatures
- **SHA-256** for AIR ID generation (ensuring FIPS 140-2 compliance)
- **BLAKE2b** as an alternative hash function for future-proofing
- **TLS 1.3+** for all API communications
- **No private key storage** on the registry — agents retain sole custody of their private keys
- **Minimal PII collection** with support for privacy-preserving verification methods

These choices align with NIST's cryptographic standards guidance and the security posture requirements outlined in the concept paper.

4. Recommendations for Neutral Governance of Agent Identity Infrastructure

We close with a set of governance recommendations informed by our experience building AIR's governance charter and by the historical precedents of internet infrastructure governance.

4.1 The Case for Independent Governance

Agent identity infrastructure is, by nature, a public good. Like the Domain Name System, TLS certificate infrastructure, and internet protocol standards, it must serve all participants in the ecosystem — agent creators, operators, platforms, enterprises, and end users — without privileging any single commercial interest. The concept paper's vision of broad adoption and interoperability is best served by governance structures that are demonstrably neutral.

We are not arguing that commercial implementations of agent identity are inappropriate. Enterprise solutions like Microsoft Entra Agent ID and Okta Auth0 for AI Agents serve legitimate market needs. Rather, we are arguing that the foundational registry and trust verification infrastructure — the layer that enables cross-organizational, cross-platform trust — should be governed by institutions whose accountability runs to the public interest.

4.2 Lessons from Internet Governance

Three precedents are especially instructive:

ICANN (1998): Established as a nonprofit to govern the DNS after it became clear that a government-operated or single-vendor-operated system could not serve the global internet. ICANN's multi-stakeholder model — with representation from governments, civil society, the technical community, and the private sector — provides a template for how agent identity governance could be structured. Key lesson: early establishment of neutral governance is far easier than retroactive reform after commercial interests have consolidated.

Let's Encrypt / ISRG (2013): Demonstrated that critical internet security infrastructure (TLS certificates) could be operated as a nonprofit public service. Starting from zero, Let's Encrypt now secures over 300 million websites on an annual budget of approximately \$5 million. Key lesson: nonprofit infrastructure can achieve massive scale when it serves a genuine public need and lowers barriers to adoption.

The OpenID Foundation: Operates a nonprofit certification program for OpenID Connect implementations, ensuring interoperability across commercial providers. Key lesson: nonprofits can coexist with and strengthen commercial ecosystems by providing neutral certification and verification services.

4.3 AIR's Governance as a Reference Model

AIR's governance charter, published in full at our public repository, was designed from inception to prevent corporate capture. We offer it as one possible reference model — not as the definitive solution — for how agent identity registries could be governed. Key structural elements include:

- **Board independence:** No corporate representative holds a board seat; board selection criteria emphasize expertise, diversity, and public service commitment
- **Committee structure:** Technical, trust, and community committees are elected by or drawn from the community, not appointed by corporate sponsors
- **Financial safeguards:** No single funding source may exceed 30% of revenue; no pay-to-play influence on trust scores or governance decisions; all financial statements published and independently audited

- **Transparency commitments:** Board minutes published quarterly, all specification changes subject to public RFC periods, annual community surveys incorporated into governance decisions
- **Succession planning:** Staggered board terms, documented succession procedures, and cross-training requirements to prevent key-person dependencies

4.4 Specific Governance Recommendations for NIST

We respectfully recommend that the NCCoE framework:

1. **Include governance criteria for agent identity registries** — specifying minimum requirements for transparency, conflict-of-interest management, and public accountability
 2. **Encourage the establishment of independent, nonprofit agent identity registries** as a complement to commercial solutions, analogous to the role of Let's Encrypt alongside commercial Certificate Authorities
 3. **Reference existing nonprofit governance models** (ICANN, ISRG, the OpenID Foundation) as templates for organizations operating agent identity infrastructure
 4. **Establish interoperability requirements** that prevent any single vendor or consortium from becoming a gatekeeper to agent identity services
 5. **Consider the international dimension** — agent identity infrastructure will necessarily operate across jurisdictions, and governance structures must accommodate geographic and regulatory diversity
-

5. References and Resources

Working Demonstration

A proof-of-concept demonstrating AIR ID lookup and trust score display is available at:

<https://agentidentityregistry.org/lookup>

Full Specification and Documentation

All AIR documentation is open source and publicly available:

- **Technical Specification (v0.1 Draft):** <https://github.com/ahnkwangwook-oss/agent-identity-registry/docs/SPECIFICATION.md>
- **Trust Score Methodology (v1.0):** <https://github.com/ahnkwangwook-oss/agent-identity-registry/docs/TRUST-SCORE.md>
- **Governance Charter (v1.0):** <https://github.com/ahnkwangwook-oss/agent-identity-registry/docs/GOVERNANCE.md>
- **Repository Root:** <https://github.com/ahnkwangwook-oss/agent-identity-registry>

Standards Referenced in This Comment

- W3C Decentralized Identifiers (DIDs) v1.0 — <https://www.w3.org/TR/did-core/>
- W3C Verifiable Credentials Data Model v1.0 — <https://www.w3.org/TR/vc-data-model/>
- IETF RFC 6749 — The OAuth 2.0 Authorization Framework
- IETF RFC 8785 — JSON Canonicalization Scheme
- OpenID Connect Core 1.0
- SPIFFE — Secure Production Identity Framework for Everyone (<https://spiffe.io>)
- IETF AIMS Draft — draft-klrc-aiagent-auth-00 (March 2026)
- OWASP Agent Name Service (ANS) v1.0 (May 2025)
- NIST AI Risk Management Framework (AI RMF 1.0)
- NIST Cybersecurity Framework 2.0

Conclusion

The NCCoE concept paper on accelerating the adoption of software and AI agent identity and authorization represents an important step toward establishing the trust infrastructure that the agentic era demands. We commend NIST for its leadership in convening this effort and for the rigor of the concept paper's analysis.

AIR's contribution to this effort is as a neutral implementation partner. We do not seek to replace the standards and protocols referenced in the concept paper. We seek to complement them with a consumer-facing trust layer, a comprehensive trust scoring methodology, and a governance model designed to serve the public interest. We believe that the combination of NIST's standards authority, the technical community's protocol expertise, and independent nonprofit registries like AIR can produce agent identity infrastructure worthy of the trust that society will increasingly place in AI agents.

We welcome further dialogue and stand ready to contribute to any follow-on working groups, pilot programs, or reference implementations that emerge from this comment process.

Respectfully submitted,

Agent Identity Registry Foundation 501(c)(3) Nonprofit Corporation San Francisco, California

foundation@agentidentityregistry.org <https://agentidentityregistry.org>